

Obsero application architecture (SOC 2 / penetration testing)

Audience: SOC 2 reviewers, penetration testers, security questionnaires
Status: Current-state (as implemented in repo)
Last updated: 2026-09-15
Format: Mermaid flowchart / sequenceDiagram in Markdown (no C4). Render via GitHub, Cursor + Mermaid preview extension, or mermaid.live

How to use this pack

Doc	What it answers
01-system-context.md	Who talks to Obsero, and which third parties we depend on
02-containers.md	Runtime topology: Heroku, GCE, Cloudflare, Atlas, Redis, GCS, R2
03-trust-boundaries-auth.md	Auth surfaces, roles, public vs authenticated entry points
04-data-flows.md	Security-relevant flows (login, queries, exports, agent analytics, MCP)
05-data-stores.md	Where data lives, sensitivity notes, encryption posture

Out of scope here: feature-level product docs, GCP migration *plans* that are not yet live, and secrets/credentials (never included).

Environment naming (prod)

Surface	Typical hostname
Web app (SPA + API)	app.obsero.ai
Public HTTP API	api.obsero.ai
MCP server	mcp.obsero.ai
Agent-analytics ingest	Cloudflare Worker (e.g. analytics*.obsero.ai)
Staging app	staging.app.obsero.ai
Staging public API	api-staging.obsero.ai

Heroku apps (reference): production `obsero`, staging `obsero-staging`. Separate Heroku app for MCP.

Viewing / exporting diagrams

1. Open the `.md` files in GitHub preview, or in Cursor with the **Markdown Preview Mermaid Support** extension (`Cmd+Shift+V`).

2. **Single PDF (diagrams rendered):** Obsero-Architecture-SOC2.pdf in this folder.
Regenerate with `generate-pdf.cjs` (needs `puppeteer` + `marked` — see script header).
 3. For one-off PNG/SVG: paste a `mermaid` block into mermaid.live → Export.
 4. Source of truth is the Markdown — treat the PDF as a shareable snapshot for auditors.
-

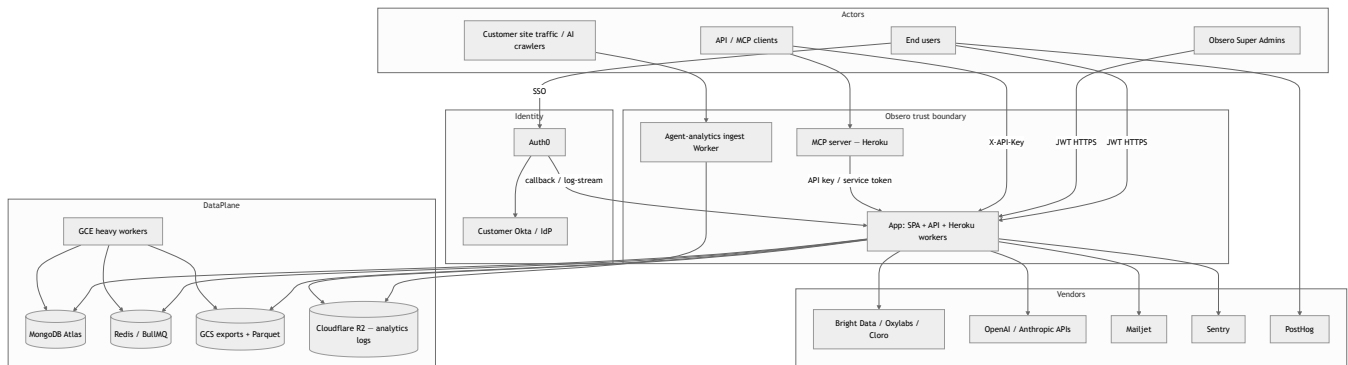
Related deep-dive docs (implementation detail)

Topic	Doc
SSO (Auth0 + Okta)	../sso/SSO_IMPLEMENTATION.md
Public exporter / insights API	../exporter-api/PUBLIC_API_PLAN.md
MCP	../mcp/MCP_IMPLEMENTATION.md
Agent analytics ingest	../agent-analytics/INGEST_BEACON_ARCHITECTURE.md
Heavy workers (GCE)	../infra/GCP-migration/HEROKU_ORCHESTRATOR_GCP_HEAVY_PLAN.md
Terraform (GCS, GCE, CF)	../../../../infra/terraform/README.md

01 — System context

Purpose: External actors and third-party systems that interact with Obsero.

Audience: SOC 2 / pen test — "what touches the system boundary?"



Notes for reviewers

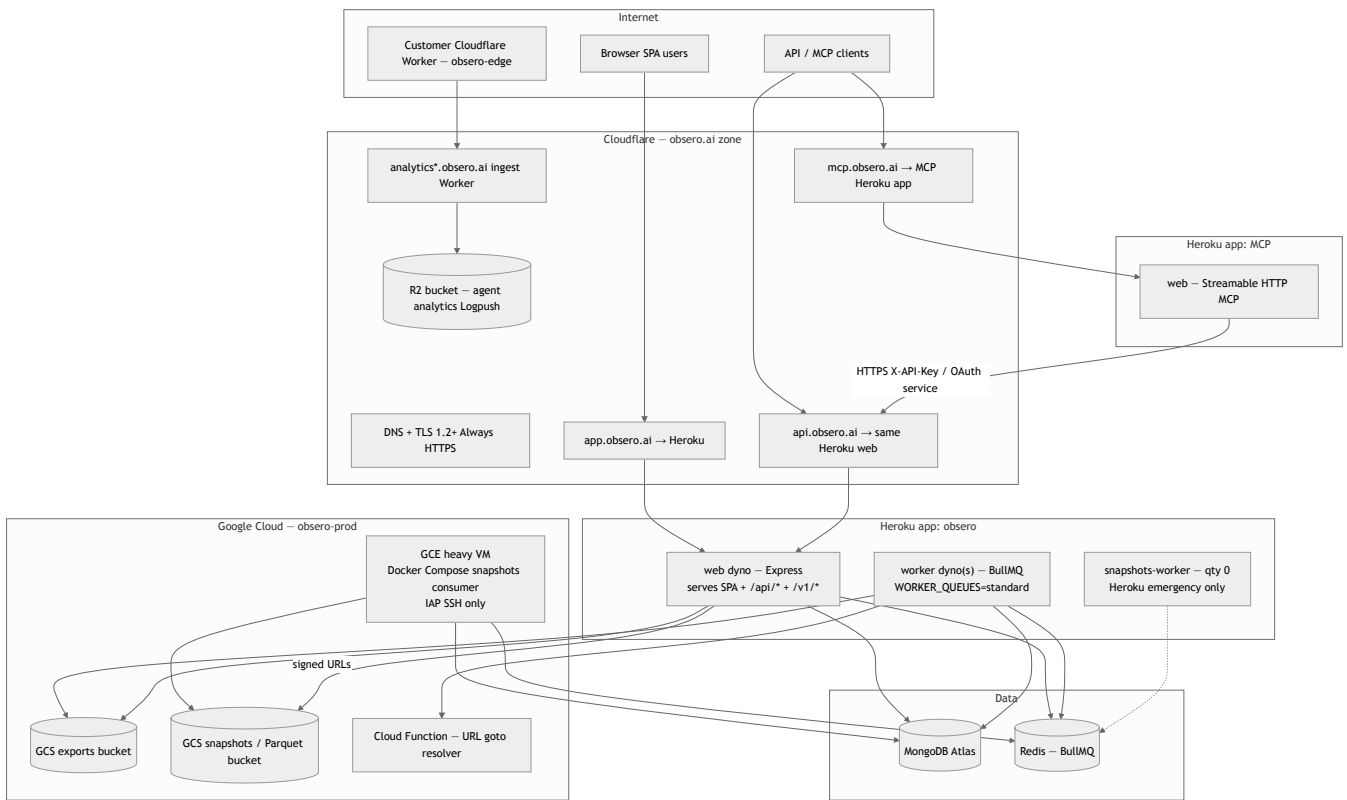
- **Obsero does not host customer websites.** Agent analytics relies on a customer-deployed Cloudflare Worker (`obsero-edge`) that optionally forwards beacons to Obsero ingest.
- **MCP does not hold a separate datastore.** It calls Obsero's public `/v1/*` API.
- **Marketing site** (`www.obsero.ai`) is Framer — outside the application trust boundary of this pack.

02 — Containers (C2) — runtime topology

Purpose: Deployable units, process roles, and network relationships.

Audience: SOC 2 / pen test — “what runs where?”

Production container view

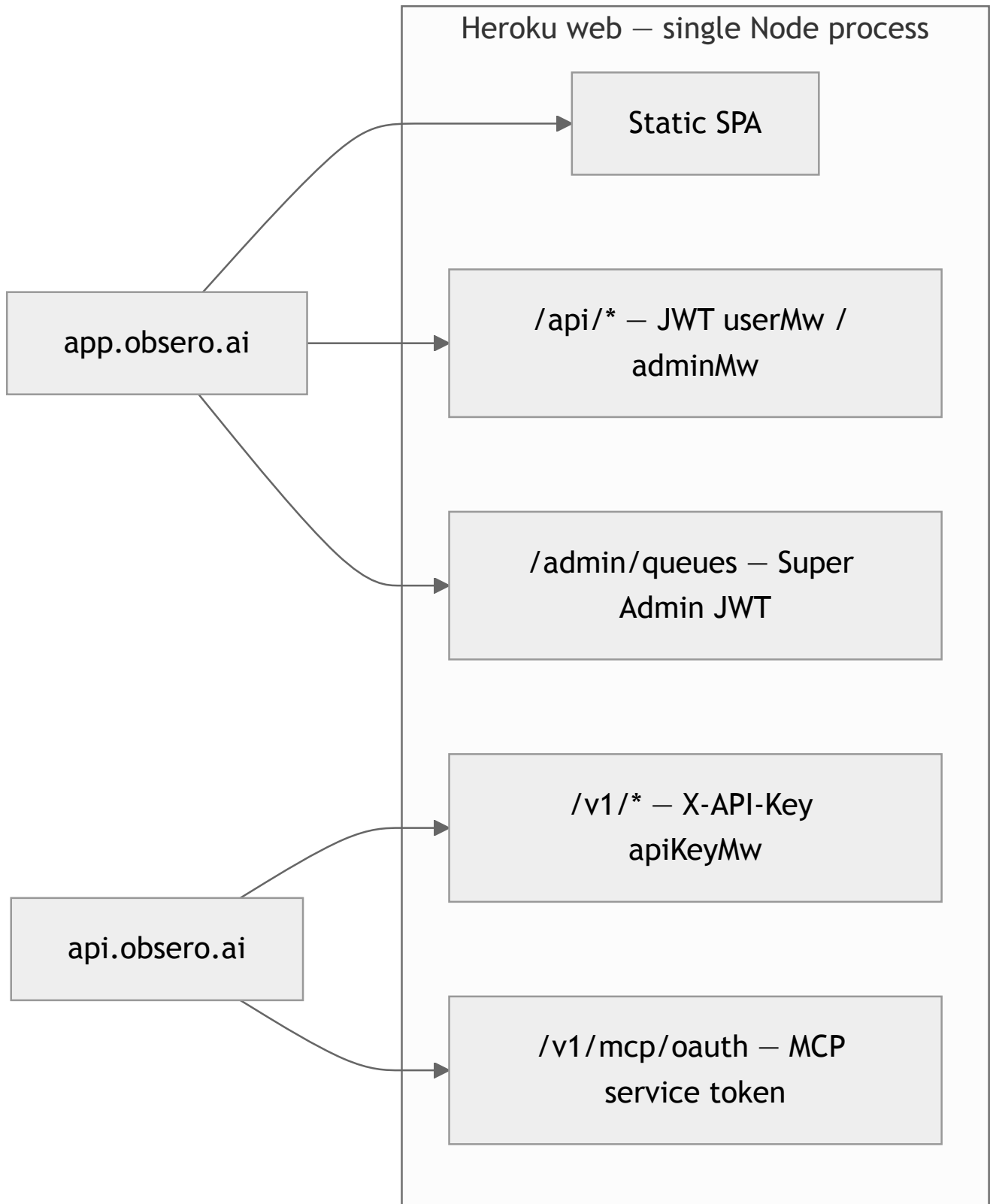


Process formation (prod reference)

From Procfile + HEROKU_PROD_FORMATION in constants.ts :

Process	Role	Notes
web	Express API + static SPA (front/dist)	Performance-M
worker	BullMQ standard queues (queries, crawl, exports, agent-analytics import, ...)	Performance-M × N
snapshots-worker	BullMQ snapshots	qty 0 while GCE is sole snapshot consumer (SNAPSHOT_ON_HEROKU=false)
MCP web	Separate Heroku app	Thin adapter to /v1/*
GCE Compose snapshots	Heavy snapshot builds	Same back/dist/worker.js , WORKER_QUEUE=snapsots

Same binary, two auth surfaces on one web dyno



Optional host allow-list: `PUBLIC_API_ALLOWED_HOSTS` can restrict `/v1/*` to `api.obsero.ai` / `api-staging.obsero.ai`.

Security-relevant infrastructure controls

Control	Implementation
TLS to clients	Cloudflare zone SSL strict , Always HTTPS, min TLS 1.2 (<code>infra/terraform/cloudflare</code>)
Trust proxy	Express <code>trust proxy = 1</code> (Heroku + CF)
Helmet CSP	Enabled when <code>NODE_ENV=production</code> on SPA responses
GCE SSH	IAP-only — no public app ports on heavy VM
Atlas / Redis	Network allowlists include Heroku + heavy VM static IP
Secrets	Heroku config vars; GCE via GCP Secret Manager (not in Terraform state)

Staging

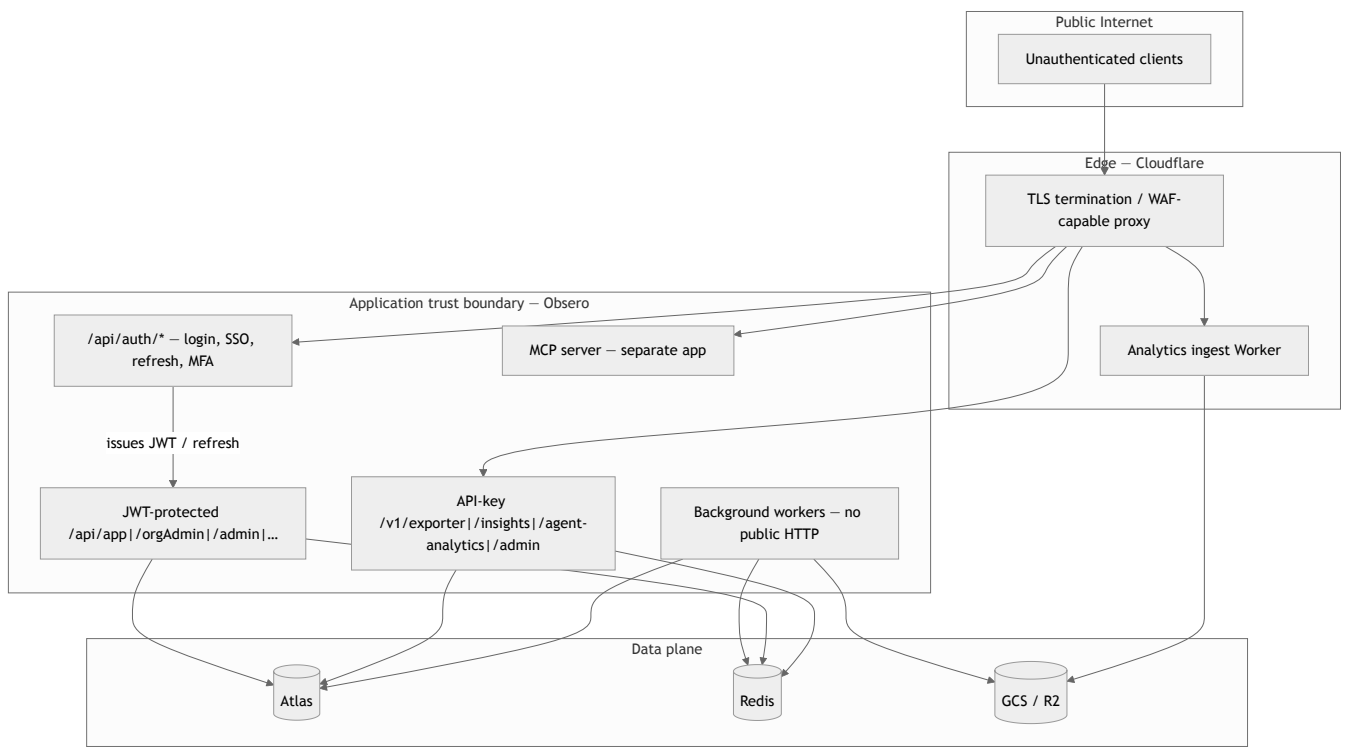
Parallel stack: `obsero-staging` Heroku app, staging Atlas cluster, staging GCS/R2/GCE as provisioned. Staging serves `robots.txt` `Disallow-all`.

03 — Trust boundaries and authentication

Purpose: Entry points, auth mechanisms, and role boundaries for pen-test scoping.

Audience: SOC 2 / penetration testers.

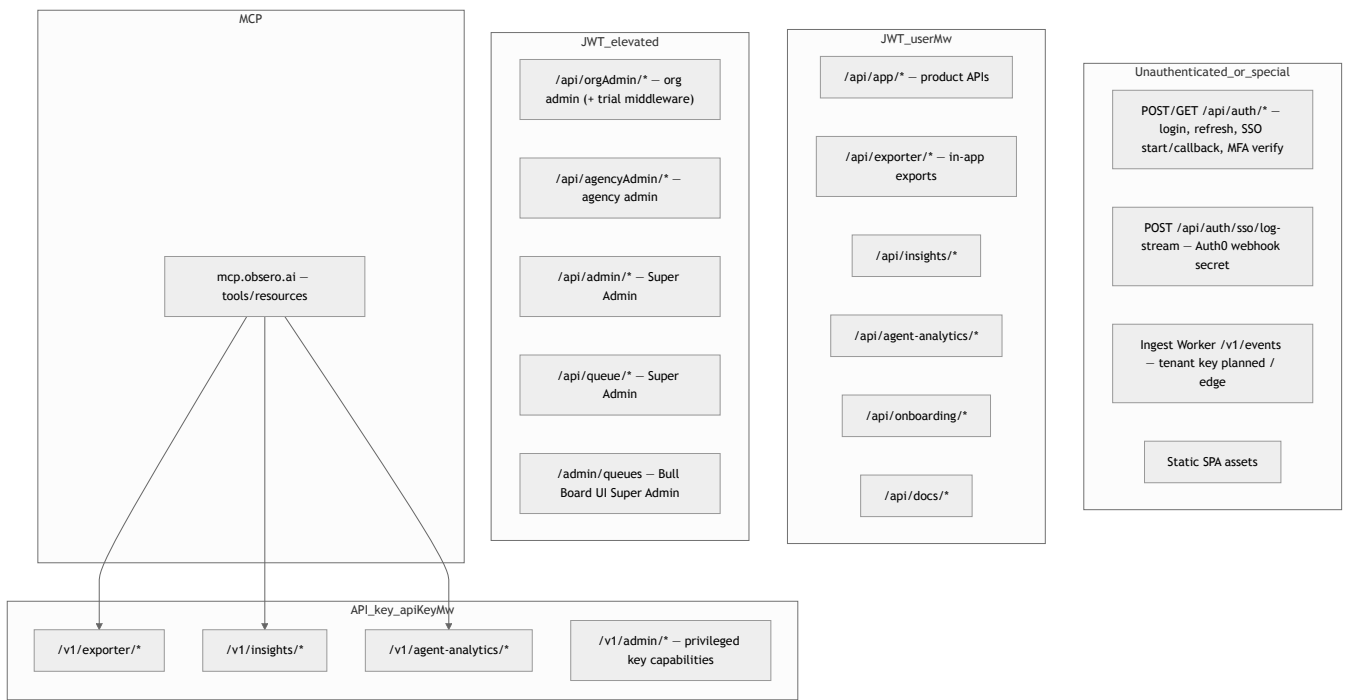
Trust boundaries (summary)



Authentication mechanisms

Mechanism	Where used	Credential	Session / scope
Password + JWT	SPA → /api/*	Email/password; bcrypt password hashes in Mongo	Access JWT + refresh token (hashed in Mongo)
Email MFA	Super Admin / Org Admin login (prod)	One-time code via Mailjet	Completes login → JWT; skipped for authProvider: 'sso'
SSO (Auth0 → Okta SAML)	Enterprise orgs	IdP assertion via Auth0	JIT/sync user; Obsero issues own JWT
Org API key	api.*/v1/*, MCP	X-API-Key: obsk_... (SHA-256 hashed at rest)	Org-scoped; trial orgs blocked on public API
MCP service token	/v1/mcp/oauth	Shared service secret between MCP ↔ API	Machine-to-machine
Auth0 log stream	POST /api/auth/sso/log-stream	Bearer AUTH0_LOG_STREAM_SECRET	SCIM disable/re-enable users

HTTP surface map (pen-test inventory)



Mount wiring: `back/src/routes/api.ts` , `back/src/server.ts` .

Role model (application)

Role	Typical capabilities
Marketeer / standard user	Org-scoped product data for assigned org(s)
Organisation Admin	Org settings, invites (blocked when <code>ssoEnforced</code>), MFA on login
Agency Admin / Manager	Multi-org within agency; agency admin APIs
Super Admin (<code>permissions.isAdmin</code>)	Cross-org admin, Bull Board, queue tools; email MFA

Tenant isolation: Handlers resolve organisation via `getEffectiveOrgId` / API-key org binding. Super-admin and agency-admin paths can intentionally override org context within policy.

SSO enforcement: When `organization.ssoEnforced` , password login and password-invite flows are blocked for that org’s users.

Tokens and secrets (non-exhaustive, no values)

Secret class	Storage
<code>JWT_SECRET</code> / refresh secret	Heroku config
API key material	Only hash + prefix in Mongo; plaintext shown once at creation
Provider keys (Bright Data, Oxylabs, Cloro, OpenAI, Anthropic, Mailjet, Auth0, GCS)	Heroku / Secret Manager

Secret class	Storage
Refresh tokens	Hashed entries in Mongo

Deliberate exceptions (call out to testers)

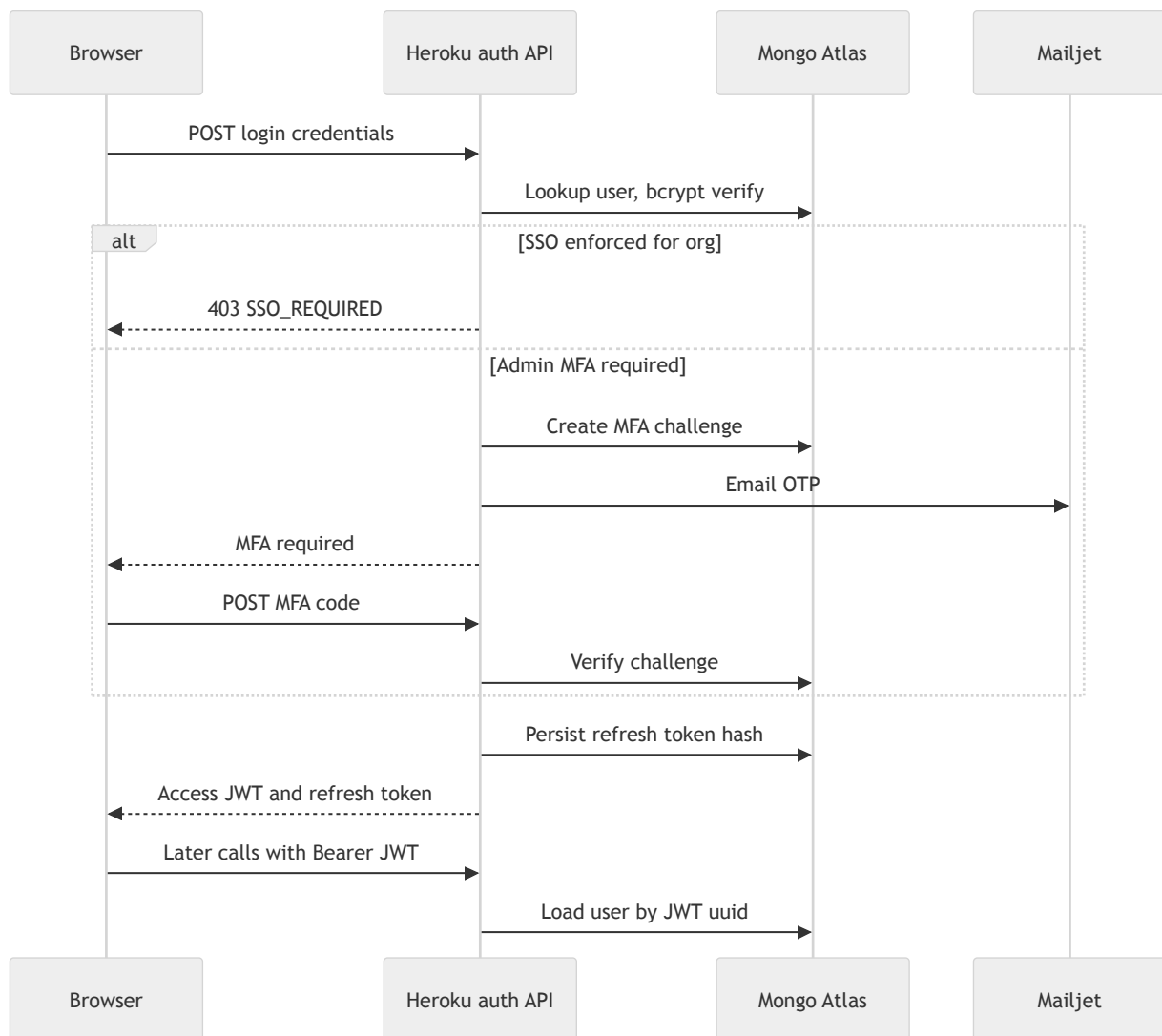
Item	Behaviour
<code>cors()</code>	Open CORS middleware on API — rely on auth tokens, not browser origin alone
Bull Board static assets	CSS/JS under <code>/admin/queues</code> served without auth; HTML/API requires Super Admin JWT (token may be query <code>?token=</code> for SPA)
Media proxy	<code>/api/app/media/*</code> may accept <code>?token=</code> because <code></code> cannot set <code>Authorization</code>
JSON body limit	15mb globally (large org payloads)

04 — Security-relevant data flows

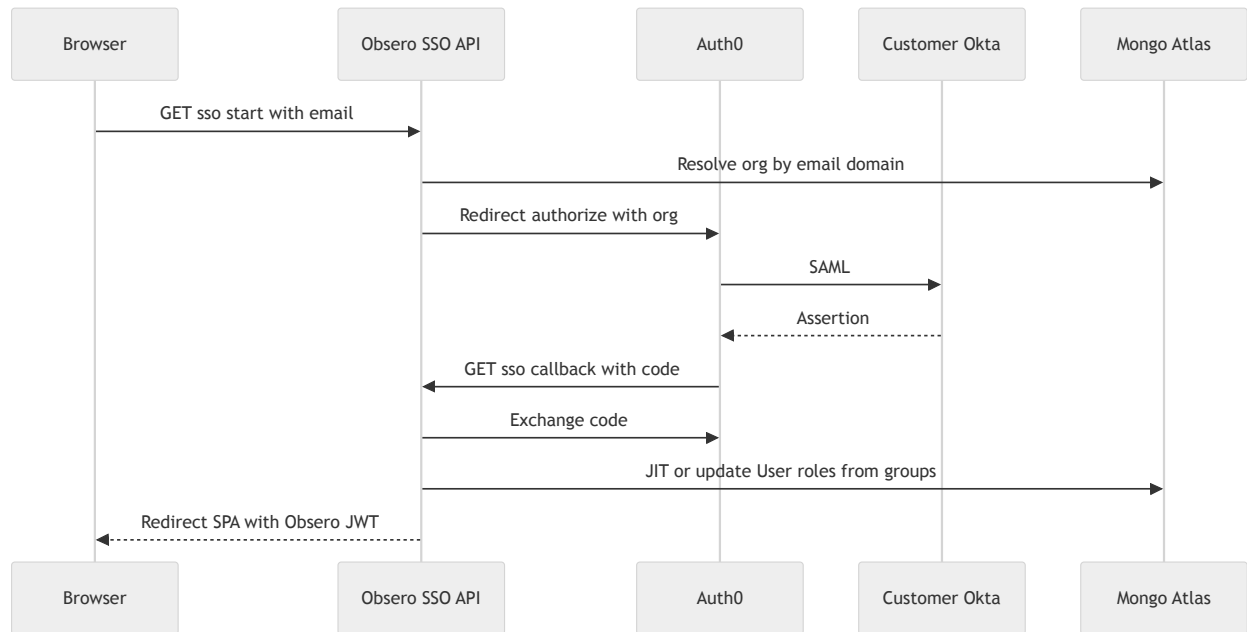
Purpose: End-to-end flows auditors and pen testers usually walk.

Audience: SOC 2 / penetration testing.

1. Password login + MFA to JWT

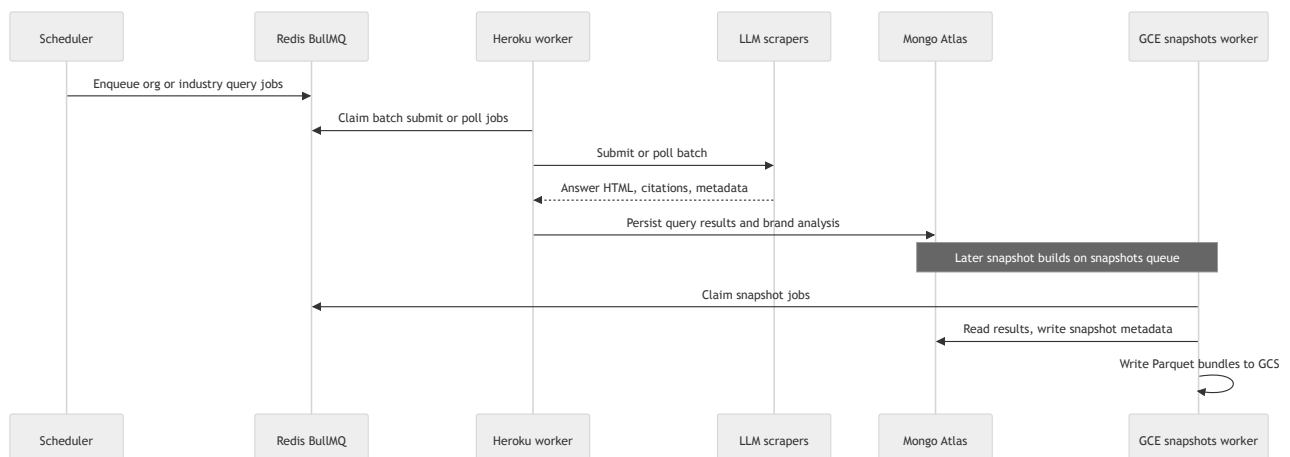


2. Enterprise SSO (Auth0 + Okta)



SCIM offboard: Auth0 Event Stream → `POST /api/auth/sso/log-stream` (shared secret) → disable Mongo user.

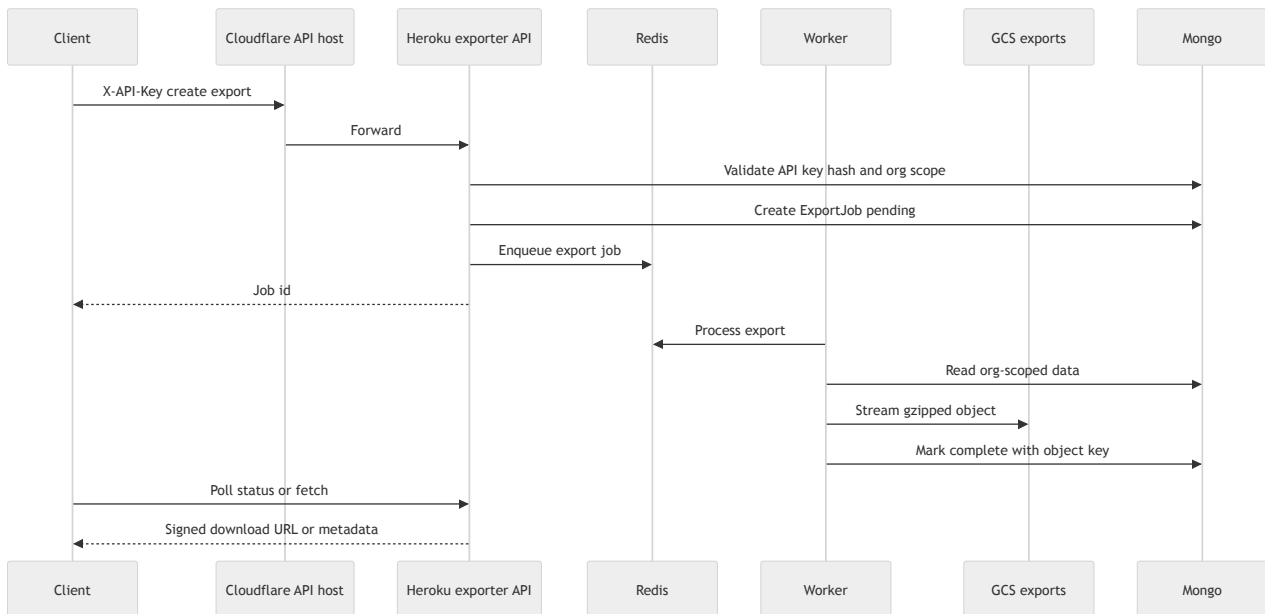
3. Scheduled LLM visibility query (batch path)



Data leaving Obsero: Prompt text and locale/location parameters to scraper/LLM vendors.

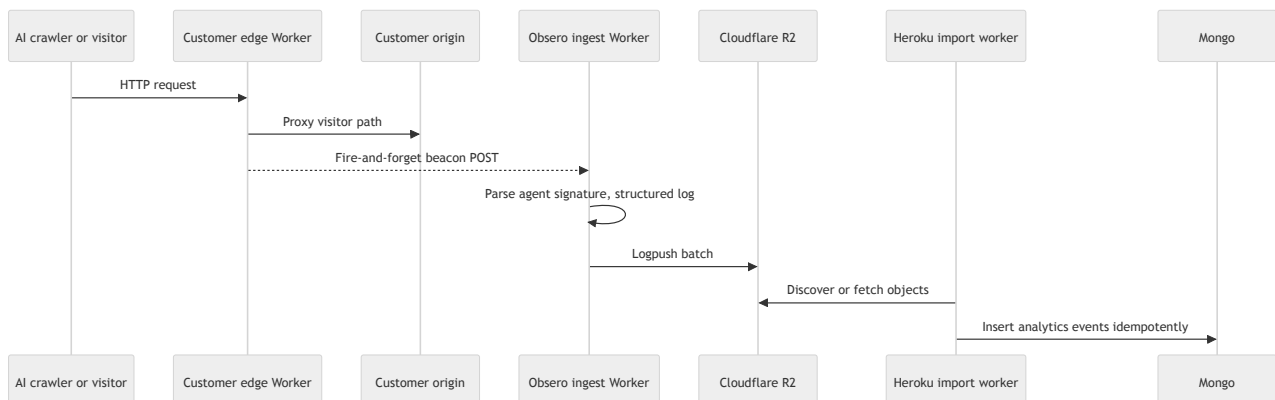
Data returning: Model answers, citation URLs, optional HTML fragments — stored in Atlas (and derived snapshots in GCS).

4. Public API export (API key)



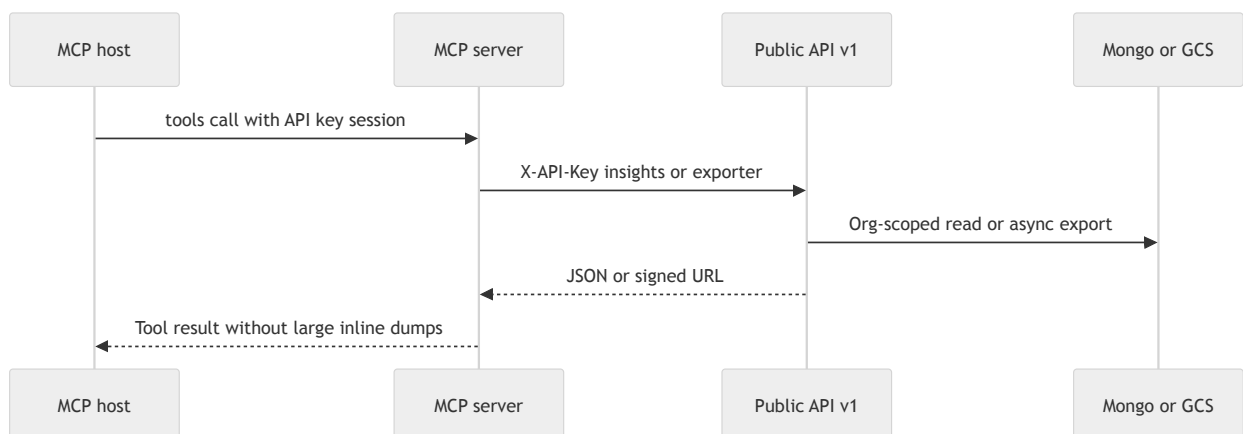
In-app path is identical handlers on `/api/exporter/*` with JWT (`userMw`) instead of `apiKeyMw` .

5. Agent analytics beacon to Mongo



Beacon fields are edge-controlled (UA, path, sec-fetch-*, not cookies). Some loss is acceptable for v1 analytics.

6. MCP client to Obsero data



MCP holds **no** primary customer database; API remains the authorization boundary.

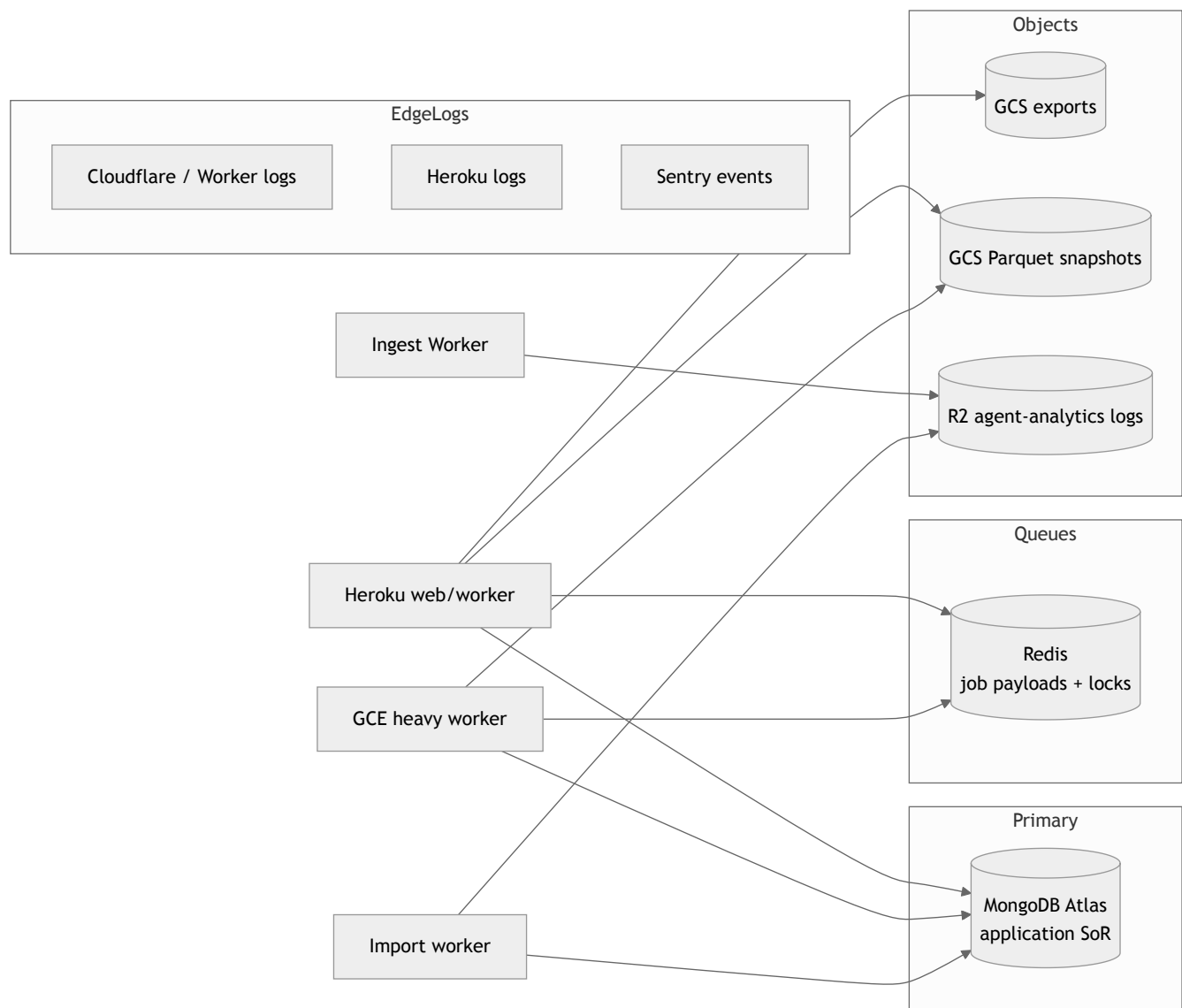
Pen-test focus suggestions

Area	Why
/api/auth/* + MFA bypass / SSO domain mapping	Account takeover
Org IDOR on /api/app/* and /v1/*	Cross-tenant data access
API key privilege (super-admin / agency keys)	Horizontal/vertical escalation
Bull Board /admin/queues	Privileged ops surface
Export signed URLs	Object ACL / expiry
Ingest Worker auth & abuse	Cost / injection into analytics
SSRF via crawl / goto resolver / content optimiser URL fetch	Server-side request forgery

05 — Data stores and classification

Purpose: Where sensitive data lives for SOC 2 questionnaires and pen-test scoping.
Audience: Auditors / security reviewers.
Note: Classification labels below are engineering guidance for reviews — confirm with legal/compliance for customer contracts.

Store inventory



Data classes (high level)

Class	Examples	Primary location	Notes
Account PII	User name, email, org membership, roles	Atlas User / Organization	Auth + admin UIs
Auth secrets	Password hashes (bcrypt), refresh token hashes, API key	Atlas	Plaintext passwords/keys never stored

Class	Examples	Primary location	Notes
	hashes		
Customer content config	Tracked prompts, brands, competitors, locales	Atlas	Business confidential
LLM outputs	Answers, citations, HTML fragments, brand analysis	Atlas MigratedQueryResult / related	May include third-party page content quoted by models
Derived analytics	Visibility/citation snapshots, sentiment	Atlas metadata + GCS Parquet	Signed URL download to browsers (DuckDB-WASM)
Exports	Customer-requested dumps	GCS + ExportJob in Atlas	Time-limited signed URLs
Agent analytics	Crawler UA/path beacons	R2 then Atlas	Designed without cookies; customer edge filters
Ops telemetry	Errors, product analytics	Sentry, PostHog	CSP allowlisted endpoints
Job metadata	BullMQ payloads	Redis	May include org/query IDs; treat as sensitive

Encryption and access posture (as designed)

Layer	Posture
In transit	HTTPS to clients (CF TLS ≥ 1.2); TLS to Atlas, Redis providers, GCS, vendor APIs
At rest	Atlas / GCS / R2 provider-managed encryption; Redis provider defaults
App secrets	Heroku config vars; GCE Secret Manager for heavy worker env
Object access	GCS via service accounts; browser access via short-lived signed URLs
Admin access	Super Admin JWT; GCE SSH via IAP only

Third-party processors (subprocessors — engineering list)

Vendor	Purpose
Heroku	App hosting
Cloudflare	DNS, TLS, Workers, R2, API edge
MongoDB Atlas	Database
Redis (Heroku Redis / Redis Cloud)	Queues
Google Cloud	GCS, GCE, Cloud Function goto resolver
Auth0	SSO federation
Customer IdP (e.g. Okta)	SAML IdP for SSO customers
Mailjet	Transactional email
Bright Data / Oxylabs / Cloro	LLM UI / answer scraping
OpenAI / Anthropic	Direct model APIs (analysis, Claude provider, categorisation, etc.)

Vendor	Purpose
Sentry	Error monitoring
PostHog	Product analytics

Formal subprocessors list for customers should be maintained by compliance; this table mirrors **code dependencies**.

What is not in scope of this architecture pack

- Exact retention schedules (product/legal policy)
- Backup/restore RTO/RPO numbers (ops runbooks)
- Employee laptop / MDM controls
- Marketing site (Framer) content CMS